КАК ЧИТАТЬ ОТЧЕТ

Подробный разбор HTML/JSON-отчета EH/Unwind Analyzer: каждый блок, каждое важное поле и связь с разметкой Ghidra.

1. Что такое отчет проекта

Отчет EH/Unwind Analyzer - это результат анализа PE x64 файла. Он может быть статическим, динамическим или смешанным. Статический слой читает PE-структуры, секции, .pdata, .xdata и UNWIND_INFO без запуска файла. Динамический слой запускает файл под отладчиком и фиксирует регистрацию обработчиков исключений и runtime function table.

Тип запуска	Что попадет в отчет
Статика	PE validation, sections, exception directory, RUNTIME_FUNCTION, UNWIND_INFO, эвристики по размещению и обработчикам.
Динамика	События отладчика: AddVectoredExceptionHandler, AddVectoredContinueHandler, SetUnhandledExceptionFilter, RtlAddFunctionTable, RtlInstallFunctionTableCallback, hits обработчиков, exceptions.
Смешанный режим	В одном HTML/JSON будут и статические признаки, и dynamic validation. Это самый полезный режим для демонстрации combo-бинарников.

2. Верхние карточки отчета

Верхние карточки - это краткая сводка. Их количество может отличаться между версиями отчета и режимами запуска, потому что динамические карточки появляются только при наличии dynamic validation. Если раньше было 8, а стало 7, это обычно значит, что часть поля объединена, скрыта или отсутствует для конкретного режима.

Карточка/поле	Как читать
Input	Какой файл анализировался. Всегда сверяйте, что открыт нужный exe.
Tool/build	Версия анализатора и режим сборки. Для сдачи полезно показывать release-сборку.
Image base	Базовый адрес PE. Нужен, чтобы переводить RVA в VA для Ghidra.
Exception directory	Где находится таблица исключений .pdata и какой у нее размер.
Runtime functions	Сколько строк RUNTIME_FUNCTION найдено в .pdata.
Anomalous entries	Не все подозрения, а только строки RUNTIME_FUNCTION, где у декодированного UNWIND_INFO есть anomalies.
Verdict/confidence	Итоговая оценка и уверенность. Это не приговор, а приоритет для ручной проверки.
Dynamic signals	Количество значимых динамических сигналов, если запускался --dynamic.

Report metadata в JSON

Поле	Что означает
schema_version	Версия схемы JSON. Нужна, чтобы понимать совместимость отчета и валидатора.

Поле	Что означает
tool_version	Версия EH/Unwind Analyzer.
generated_at_utc	Когда отчет создан в UTC.
input_sha256	SHA-256 анализируемого файла. Помогает доказать, что отчет относится именно к этому exe.
input_size	Размер входного файла в байтах.
command_line	Команда, которой был создан отчет.
build_compiler	Компилятор, которым собран анализатор.
build_platform	Платформа сборки анализатора.
build_mode	Debug/release режим сборки анализатора.
strict_abi	Был ли включен строгий режим проверки Microsoft x64 unwind ABI.
follow_chain	Следовал ли анализатор по UNW_FLAG_CHAININFO.
max_chain_depth	Максимальная глубина прохода по chained unwind.

Assessment в JSON

Поле	Что означает
final_verdict	Итоговая категория. Например low_suspicion_static означает: статика нашла признаки, но динамика не подтвердила сильную вредоносную активность.
final_confidence	Число 0..1. Чем выше, тем увереннее итоговая оценка.
static_evidence_level	Сила статических признаков.
runtime_evidence_level	Сила динамических признаков.
case_strength	Насколько собранный случай убедителен: например strong_unconfirmed_case.
static_dynamic_correlation	Есть ли прямое совпадение между статическими подозрениями и динамическими событиями.
dynamic_signal_count	Сколько динамических сигналов вошло в итог.
weakening_rule_count	Сколько правил снизило подозрительность.
manual_validation_steps	Список ручных шагов проверки, сформированный по найденным признакам.

3. Почему 'Аномальные записи' могут быть 0

Это поле специально узкое. Оно считает только аномалии внутри отдельных строк RUNTIME_FUNCTION/UNWIND_INFO. Туда не входят все подозрения проекта. Например, writable section, unusual section, handler dominance, reuse ratio, dynamic events и PE placement показываются в других блоках.

Такой подход правильный, потому что иначе одна карточка смешала бы разные уровни анализа: форматные ошибки UNWIND_INFO, эвристики размещения, поведение при запуске и итоговую оценку. Для комиссии это можно объяснить так: 'Аномальные записи' - счетчик низкоуровневых ошибок таблицы функций, а остальные признаки вынесены в отдельные разделы, чтобы аналитик видел источник каждого вывода.

Признак	Где искать
UNWIND_INFO anomalies	Карточка Anomalous entries и таблица Runtime functions.
Writable/unusual/exec section	Heuristic findings / Static evidence.
Handler target in writable/non-exec section	Heuristic findings и Runtime functions.
VEH/VCH/UEF registration	Dynamic validation events.
RtlAddFunctionTable / RtlInstallFunctionTableCallback	Dynamic validation events и manual validation plan.
Итоговая подозрительность	Assessment / Verdict / Confidence.

4. PE validation

PE validation проверяет базовую корректность PE-разметки: не выходят ли секции за файл, не пересекаются ли raw/virtual диапазоны, не указывает ли exception directory за пределы образа. Если здесь есть ошибки, отчет по unwind надо читать осторожнее: часть RVA может быть намеренно испорчена.

Поле	Что означает
section_raw_oob	Секция по raw offset/size выходит за границы файла.
section_virtual_oob	Секция по virtual address/size выходит за SizeOfImage.
section_raw_overlaps	Raw-диапазоны секций пересекаются.
section_virtual_overlaps	Virtual-диапазоны секций пересекаются.
section_misaligned	Секция нарушает ожидаемое выравнивание.
exception_directory_oob	PE Exception Directory указывает за пределы допустимых данных.

5. Sections

Раздел Sections показывает PE-секции: имя, RVA, virtual size, raw offset, raw size и права. Для анализа unwind особенно важны .pdata, .xdata, .text и любые необычные секции вроде .weird.

Поле	Что смотреть
name	Имя секции. .pdata обычно хранит RUNTIME_FUNCTION, .xdata - UNWIND_INFO.
rva/virtual size	Где секция находится в памяти.
raw offset/raw size	Где секция лежит в файле.
read/write/execute	Права секции. Writable metadata или executable .xdata требуют ручной проверки.

6. Heuristic analysis

Эвристики не доказывают вредоносность сами по себе. Они говорят, какие признаки необычны для нормальной компиляторной разметки Windows x64. Сильный признак важнее слабого, но окончательный вывод лучше делать по сочетанию статических и динамических данных.

Поле	Значение
score	Числовая сумма признаков.
suspicion	Низкая/средняя/высокая подозрительность по статике.
confidence	Уверенность модели эвристик.
requires_manual_review	Проект считает, что без ручной проверки вывод неполный.
evidence_level	Сила статических доказательств: weak/medium/strong.
weak/medium/strong_finding_count	Сколько признаков найдено по уровням.
evidence_families	Какие семейства признаков сработали: PE, unwind, handler, dynamic и т.п.
findings	Список конкретных сработавших признаков с уровнем и названием.

Полный смысл ключей heuristic_analysis

Ключ	Что означает
total	Общее количество сработавших признаков.
pe_section_raw_oob / pe_section_virtual_oob	Секции выходят за допустимые raw/virtual границы.
pe_section_raw_overlaps / pe_section_virtual_overlaps	Секции пересекаются в файле или в памяти.
pe_section_misaligned	Нарушено ожидаемое выравнивание секции.
pe_exception_directory_oob	Exception Directory указывает за пределы допустимой области.
rf_invalid_ranges	В RUNTIME_FUNCTION begin/end некорректны.
rf_oob	Диапазон функции выходит за образ.
rf_unwind_oob	UNWIND_INFO указывает за допустимые данные.
rf_unsorted	Таблица .pdata не отсортирована как ожидается.
rf_overlaps	Диапазоны функций пересекаются.

Ключ	Что означает
rf_duplicate_begins	Несколько записей начинаются с одного RVA.
unwind_parse_fail	UNWIND_INFO не удалось разобрать.
unwind_anomalies	Низкоуровневые аномалии внутри decoded UNWIND_INFO.
unwind_abi_warnings	Предупреждения по Microsoft x64 ABI, если включен strict ABI.
unwind_unusual_section	UNWIND_INFO находится не в типичной .xdata.
unwind_exec_section	UNWIND_INFO лежит в исполняемой секции.
unwind_writable_section	UNWIND_INFO лежит в writable секции.
handler_nonexec_section	Handler указывает в неисполняемую секцию.
handler_writable_section	Handler находится в writable секции.
unwind_reuse_ratio / unwind_unique_ratio	Показывает, насколько сильно переиспользуются одни и те же UNWIND_INFO.
handler_count / handler_reuse_ratio	Сколько handler найдено и насколько они переиспользуются.
weakening_rules_applied	Правила, которые снижают подозрительность, если картина похожа на benign compiler/runtime.
details	Дополнительные пояснения, которые помогают понять источник признаков.

7. Dynamic validation

Динамический слой показывает, что реально произошло при запуске под отладчиком. Он не всегда видит весь путь исполнения, но фиксирует важные точки: регистрацию обработчиков, вызовы runtime table API, исключения и попадания в breakpoints.

Поле	Что означает
enabled/ran/ok	Был ли включен dynamic mode, запускался ли он и завершился ли штатно.
timed_out	Достигнут timeout. Если true, часть поведения могла не успеть проявиться.
exceptions_seen	Сколько исключений увидел отладчик.
first_chance_seen/second_chance_seen	Исключения до обработки и после неудачной обработки.
veh_registrations/vch_registrations	Сколько раз зарегистрированы vectored exception/continue handlers.
uef_set_calls	Сколько раз установлен unhandled exception filter.
rtl_add_function_table_calls	Вызовы RtlAddFunctionTable. Важны table/count/base.
rtl_install_function_table_cb_calls	Вызовы RtlInstallFunctionTableCallback. Важны id/base/length/callback.
events	Человекочитаемый журнал событий.
trace	Подробная трасса/служебные сообщения отладчика.

Полный смысл ключей dynamic_validation

Ключ	Что означает
target_exited / target_exit_code	Завершился ли анализируемый процесс и с каким кодом.
timeout_ms / trace_steps	Настройки dynamic mode: лимит времени и глубина single-step трассировки.
instrumentation_complete	Удалось ли поставить основные breakpoints и подготовить отладчик.
modules_observed_peak	Максимальное число модулей, увиденных в процессе.
module_refresh_failures	Сколько раз не удалось обновить список модулей.
module_list_truncations	Был ли список модулей усечен из-за лимитов.
unwind_handlers_discovered	Сколько handler обнаружено статикой и подготовлено для breakpoints.
breakpoint_set_attempts	Сколько было попыток поставить breakpoints.
breakpoint_set_failures	Сколько breakpoints поставить не удалось.
breakpoint_capacity_drops	Сколько точек пришлось отбросить из-за лимита capacity.
pending_rearm_failures	Сколько отложенных восстановлений breakpoint не удалось.
breakpoint_rearm_failures	Сколько breakpoints не удалось восстановить после срабатывания.
unwind_handler_bp_set / unwind_handler_hits	Поставлены ли breakpoints на unwind handlers и были ли попадания.
veh_hits / vch_hits / uef_hits	Были ли реальные переходы в соответствующие обработчики.
dynamic_signal_count	Сколько динамических сигналов зачтено в итоговую оценку.

Ключ	Что означает
dropped_events	Сколько событий не попало в журнал из-за лимита.
details	Краткие диагностические строки.
events	Главный журнал динамики для человека.
trace	Более подробная трасса отладчика.

8. Manual validation plan

Manual validation plan формируется кодом проекта на основе assessment и найденных признаков. Это не внешний совет и не текст от нейросети. В проекте есть правила: если сработал writable unwind, необычная секция, runtime function table API или регистрации VEH/VCH/UEF, в план добавляются соответствующие шаги ручной проверки.

Почему план именно такой: он связывает найденные признаки с тем, что аналитик должен подтвердить вручную. Например, если есть RtlAddFunctionTable, одного факта вызова мало. Нужно посмотреть table, count, base и проверить, куда указывает runtime table. Если есть VEH/VCH/UEF, нужно записать target address и пройти single-step от handler, чтобы понять, это нормальный runtime hook или перехватчик исключений.

Рекомендация	На основании чего появляется	Что сделать простыми словами
Inspect the section hosting the unwind metadata	UNWIND_INFO лежит в unusual/writable/exec секции.	Открыть секцию в отчете и Ghidra, записать RVA/raw offset/права, понять, похоже ли на нормальную .xdata.
Check writable unwind metadata or handler targets	Метаданные или обработчик находятся в writable section.	Проверить, оправдано ли это JIT/runtime-сценарием. Если нет, считать подозрительным.
Capture arguments of RtlAddFunctionTable / RtlInstallFunctionTableCallback	Динамика увидела регистрацию runtime function table.	Записать table/count/base или id/base/length/callback и посмотреть, куда эти адреса попадают.
List each VEH/VCH/UEF registration	Динамика увидела регистрацию обработчиков исключений.	Перечислить handler addresses и пошагово пройти код от обработчика.

9. Runtime functions

Runtime functions - это таблица функций из .pdata. Каждая строка описывает диапазон кода и ссылку на UNWIND_INFO. Этот блок нужен, чтобы от общей эвристики перейти к конкретной функции.

Поле	Что означает
index	Номер записи RUNTIME_FUNCTION.
begin_rva/end_rva	Диапазон кода функции в RVA.
size	Размер диапазона функции.
begin_section	В какой секции начинается функция.
unwind_rva	RVA структуры UNWIND_INFO.
unwind_section	Секция, где лежит UNWIND_INFO.
unwind_ok	Удалось ли разобрать UNWIND_INFO.
unwind_error	Причина ошибки разбора.
unwind.version/flags/prolog_size	Поля структуры UNWIND_INFO.
fixed_stack_bytes	Оценка фиксированного размера стека.
frame_reg/frame_off	Frame pointer, если он используется.
has_handler/handler_rva/handler_section	Есть ли обработчик и куда он указывает.
has_chain/chain	Есть ли chained unwind info.
anomalies/anomalies_text	Низкоуровневые аномалии конкретной записи.
comment	Готовая короткая строка, которая также импортируется в Ghidra.

10. Как читать разметку Ghidra из отчета

CSV для Ghidra строится из тех же данных, что и таблица Runtime functions. Поэтому комментарий в Ghidra - это короткая форма строки отчета.

```
begin_rva,end_rva,name,comment
0x00001000,0x00001016,sub_00001000,
UNWIND v1 flags=EHANDLER prolog=0 stack=0B
frame=-+0 saved_gp=[-] saved_xmm=[-]
handler_rva=0x00001000
```

Символ/часть	Подробное объяснение
begin_rva	Начало функции относительно ImageBase. В Ghidra адрес = ImageBase + begin_rva.
end_rva	Конец диапазона функции. Диапазон half-open: начало включается, конец не включается.
name	Имя, которое скрипт пытается поставить функции. Например sub_00001000.
comment	Текст, который будет виден в Listing/Decompiler.
saved_gp=[-]	Обычные регистры не сохраняются. Если есть RBX/RBP/RSI, они будут перечислены.
saved_xmm=[-]	XMM-регистры не сохраняются.
handler_rva	Адрес обработчика в формате RVA. Проверьте секцию и права.
parse failed	Данные UNWIND_INFO не удалось разобрать. Это отдельный повод открыть байты в Ghidra.

11. Достаточно ли отчета аналитику

Да, отчет выводит основной функционал проекта: статическую картину PE/unwind, эвристики, динамические события, итоговую оценку и план ручной проверки. Но это анализатор, а не автоматический приговор. Для защиты важно говорить: проект находит и структурирует признаки, а финальное подтверждение делается через Ghidra/отладчик по manual validation plan.